Password Policy a la carte

trimarcsecurity.com/hub-post/password-policy-a-la-carte

Brandon Colley October 11, 2022

Updated: Dec 13, 2024

It's been over 5 years since NIST famously released Special Publication 800-63B where they advised against mandatory password changes. A few years later, Microsoft came around to the idea that "mandated password changes do more harm than good." For years, researchers have been saying the same thing: forcing users to periodically change password offers very little benefit.

With so much empirical evidence to the contrary, why does Trimarc continue to stand behind password changes as an important security measure? Because administrators are just as bad at implementing password policies as end users are at following them. Instead, organizations tend to follow the guidelines that are easy and ignore the ones that keep them secure.

NIST

Starting with the elephant in the room, NIST offers the guidelines that everyone likes to site but no one likes to read. Section 5.1.1.2 (Memorized Secret Verifiers) states that "Verifiers SHOULD NOT require memorized secrets to be changed arbitrarily (e.g., periodically)." What's commonly missed are the guidelines that literally surround it. Immediately following the above quote, NIST guidelines state "verifiers SHALL force a change if there is evidence of compromise of the authenticator." Just four paragraphs above, the document further recommends that "verifiers SHALL compare the prospective secrets against a list that contains values known to be commonly-used, expected, or compromised"

Reading this document like a lawyer, you may have noticed the capitalization of SHOULD and SHALL. I have not sought legal counsel but from my understanding "shall" typically means "must" and "should" well, "should" means should. All things equal, if an organization states that they follow NIST guidelines, then they SHALL enforce both a password filter as well as password auditing.

If that 69-page document was too long to read then I'd wager its sister document, Special Publication 800-63-3 was skimmed at best. This document goes into more detail on Authenticator Assurance Levels (AAL). All organizations fall into one of three levels. Each level identifies a different set of guidance regarding authentication. AAL1 is the only level that allows for single-factor authentication. In order to truly follow NIST guidelines, organizations that fall into AAL2 or AAL3 must also follow the security guidelines for a second-factor or multi-factor authentication types.

NIST offers the following workflow diagram to assist in determining a company's AAL.

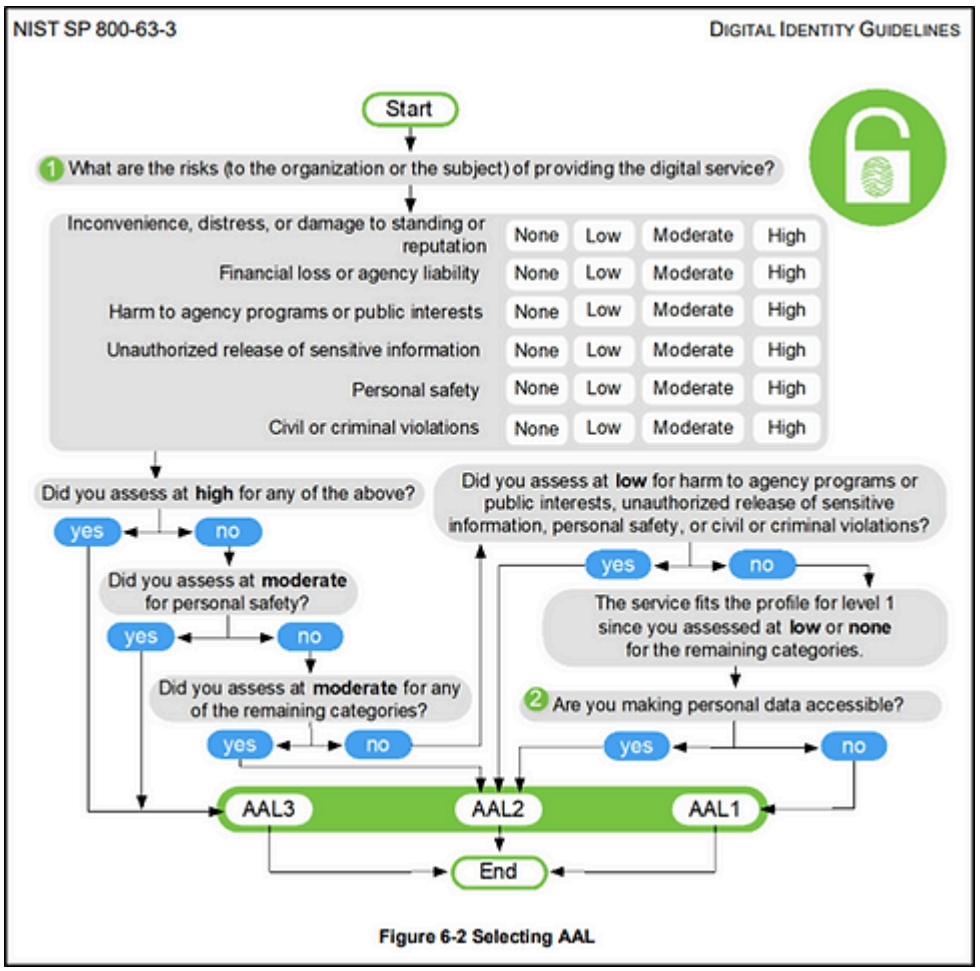


Figure 6-2 Selecting AAL

Microsoft

Microsoft begrudgingly followed NIST's lead and in 2019 declared that they were dropping password expiration policies in their security baseline. Reading beyond the tagline, they recommend "better alternatives such as enforcing banned-password lists and multi-factor authentication." Microsoft is stuck between a rock and a hard place with this recommended change to their security baseline. Their stance of moving away from on-premises solutions and focusing their attention to the cloud means that the "small set of ancient password policies enforceable through Windows' security templates" will not be expanded to support new baseline recommendations. Instead, they maintain that "Removing a low value setting from our baseline and not compensating with something else in the baseline does not mean we are lowering security standards. It simply reinforces that security cannot be achieved entirely with baselines."

It is important to fully read into these recommendations before taking measures that increase usability and decrease security. Although password expiration requirements have been removed, further recommendations follow. Microsoft documentation includes

recommendations for the use of a banned password list (such as Azure AD password protection), eliminating password reuse, and enforcing Multi-Factor Authentication.

Trimarc

At this point, it should be clear that the password expiration changes are only part of the story. Organizations need to work toward more modern methods of password protections. That said, it is undeniable that regular password changes provide little to no security benefit in many cases.

Trimarc maintains that while this might be true of unprivileged accounts, it is still an important part of administrative account hygiene. Fine-grained password policies (FGPP) should be leveraged in on-premises AD environments. A policy should be applied to Administration accounts that enforce a complex 15-character minimum password with a maximum age of 1 year. Unless a password protection solution is in place, the domain password policy should enforce a complex 12 to 15-character minimum password with a maximum age of 1 year. Furthermore, all external access should require MFA.

In addition to administrative accounts, service accounts are also a major risk factor when exempt from regular password changes. Service accounts may be at risk if granted heightened privileges or if they have an associated SPN. Account's with SPNs are especially concerning because they are susceptible to Kerberoasting. A stale or weak password could be easily cracked. Trimarc recommends a FGPP applied to all service accounts that enforce a randomized 25-character minimum password with a maximum age of 12 to 24 months or whenever a member of the admin team leaves the organization.

Conclusion

According to a 2022 study, IBM and Ponemon found the mean time to detect (MTTD) a breach was 207 days. Stale passwords may follow older, less secure password policies or may already be compromised. If either is true, this MTTD statistic is especially troubling. Periodic password changes may be the extra hurdle needed to aid in the detection of an adversary.

Good password hygiene is an ever-changing climate. All organizations are met with a decision between usability and security. This article is intended to encourage all decision makers to carefully consider all password recommendations when implementing changes to policy. The popular removal of password age requirements has been the headline for a long time and has been implemented without regard for other recommendations.

Trimarc continues to encourage the use of periodic password changes as well as adoption of MFA, password filters, and password audits. As the industry continues to move toward the next catalyst of passwordless technologies, we fear that hardening requirements will be lost in translation and will be foregone in replacement for end user comfort.

Author: Brandon Colley is Security Consultant with the Trimarc Identity Services Team.

References

